

ЛЕКЦИЯ 9

Системи за откриване и предотвратяване на нарушители

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Термини и понятия

- **Нарушение** - проблем със сигурността (**intrusion**), се нарича събитие в областта на сигурността на информацията или комбинация от множество събития, които представляват инцидент, свързан със сигурността, при който нарушител придобива или се опитва да получи достъп до система (или системен ресурс), без да има разрешение за това (RFC 2828 Internet Security Glossary).
- **Откриване на нарушение (intrusion detection):** Система за сигурност, която следи и анализира системни събития с цел откриване и известяване в реално или почти в реално време, за опит да се получи достъп до системните ресурси по неразрешен начин.

МРЕЖОВО АДМИНИСТРИРАНЕ

Термини и понятия

➤ Примери за нарушение:

- компрометиране на *remote root*
- промени/заличаване на уеб сървър
- отгатване/кракване на парола
- копиране на база данни, съдържаща номера на кредитни карти
- разглеждане на чувствителна информация без оторизация
- стартиране на *packet sniffer*
- разпространение на пиратски софтуер
- използване на незащитен отдалечен достъп до корпоративната мрежа
- използване на друга идентичност за получаване на информация
- включване на неоторизиран компютър в корпоративната мрежа

МРЕЖОВО АДМИНИСТРИРАНЕ

Термини и понятия

➤ Видове нарушители:

● Хакери

- ◆ мотивирани са от тръпката за осъществяване на достъп и / или статуса в гилдията
 - хакерската общност е силна меритокрация
 - статутът се определя от нивото на компетентност
- ◆ добронамерените нарушители консумират ресурси и легитимните потребители получават ниска производителност на системата
- ◆ Системите за откриване на проникване (IDS) и системите за предотвратяване на прониквания (IPS) са предназначени да подпомогнат борбата с хакерските заплахи като:
 - може да ограничат отдалечените влизания от/до определени IP адреси
 - може да се използва виртуална частна мрежова технология (VPN)
- ◆ Проблемът с нарушителите доведе до създаването на екипи за компютърно спешно реагиране (computer emergency response teams - CERT)

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Термини и понятия

➤ Видове нарушители:

● Престъпници

- ◆ организираните групи хакери сега са заплаха за:
 - корпорациите/ правителствата
 - срещат се в тайни (underground) форуми
 - обща цел са файловете с кредитни карти на сървърите за електронна търговия
- ◆ Хакерите престъпници обикновено имат конкретни цели
 - веднъж проникнали, действат бързо и напускат системата
- ◆ IDS / IPS може да се използва, но са по-малко ефективни
- ◆ чувствителните данни трябва да бъдат шифровани

МРЕЖОВО АДМИНИСТРИРАНЕ

Термини и понятия

➤ Видове нарушители:

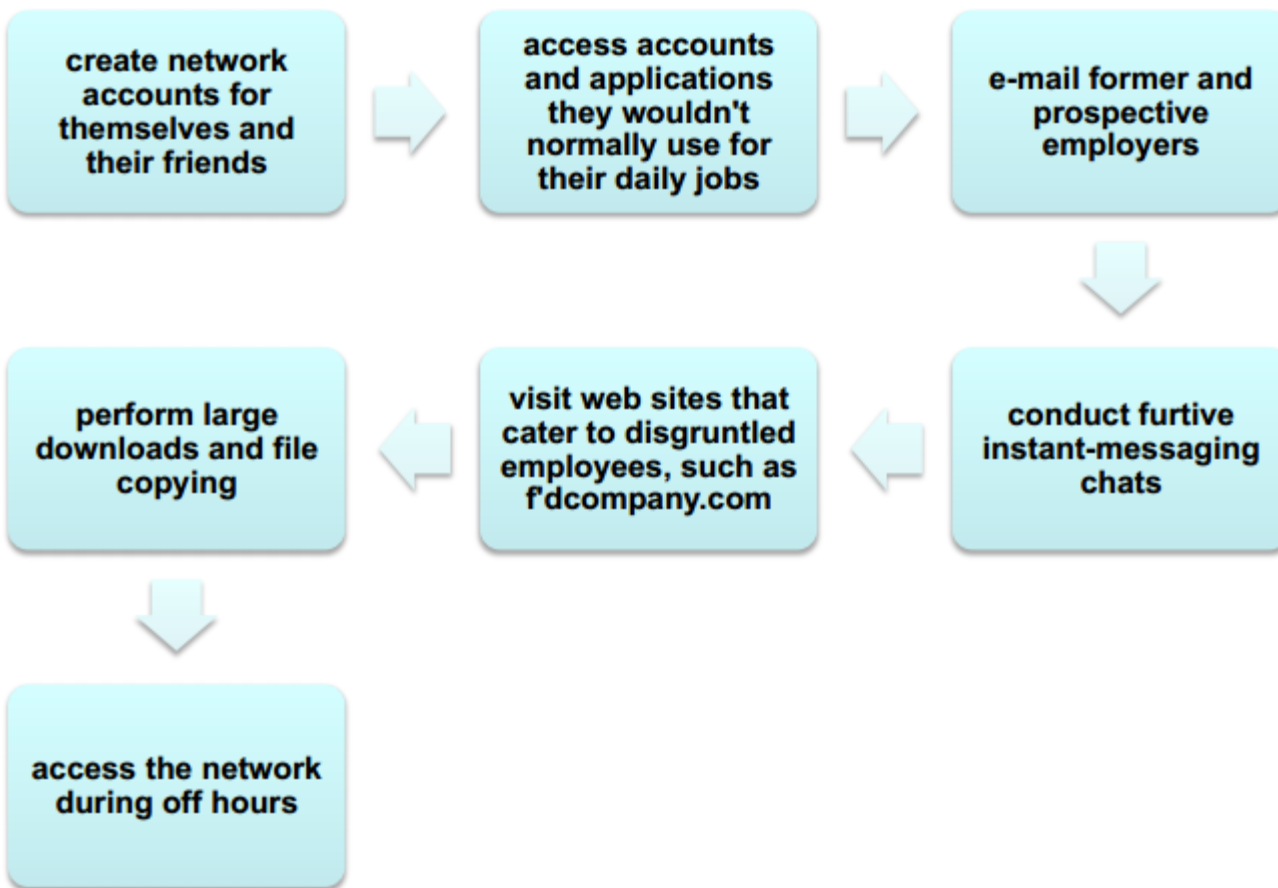
● Вътрешни атаки

- ◆ сред най-трудните за откриване и предотвратяване
- ◆ служителите имат достъп и познания за системите
- ◆ може да бъде мотивирана от отмъщение / право на собственост
 - уволнение
 - вземане на данни за клиентите при преминаване към конкурент
- ◆ IDS / IPS могат да бъдат полезни, но също така се нуждаят от:
 - прилагане на правилото за „най-малко привилегии“, мониторинг на дневниците (logs), строга автентикация, правилно управляван процес на прекратяване на правомощията

МРЕЖОВО АДМИНИСТРИРАНЕ

Термини и понятия

◆ Обичайно поведение при вътрешните атаки



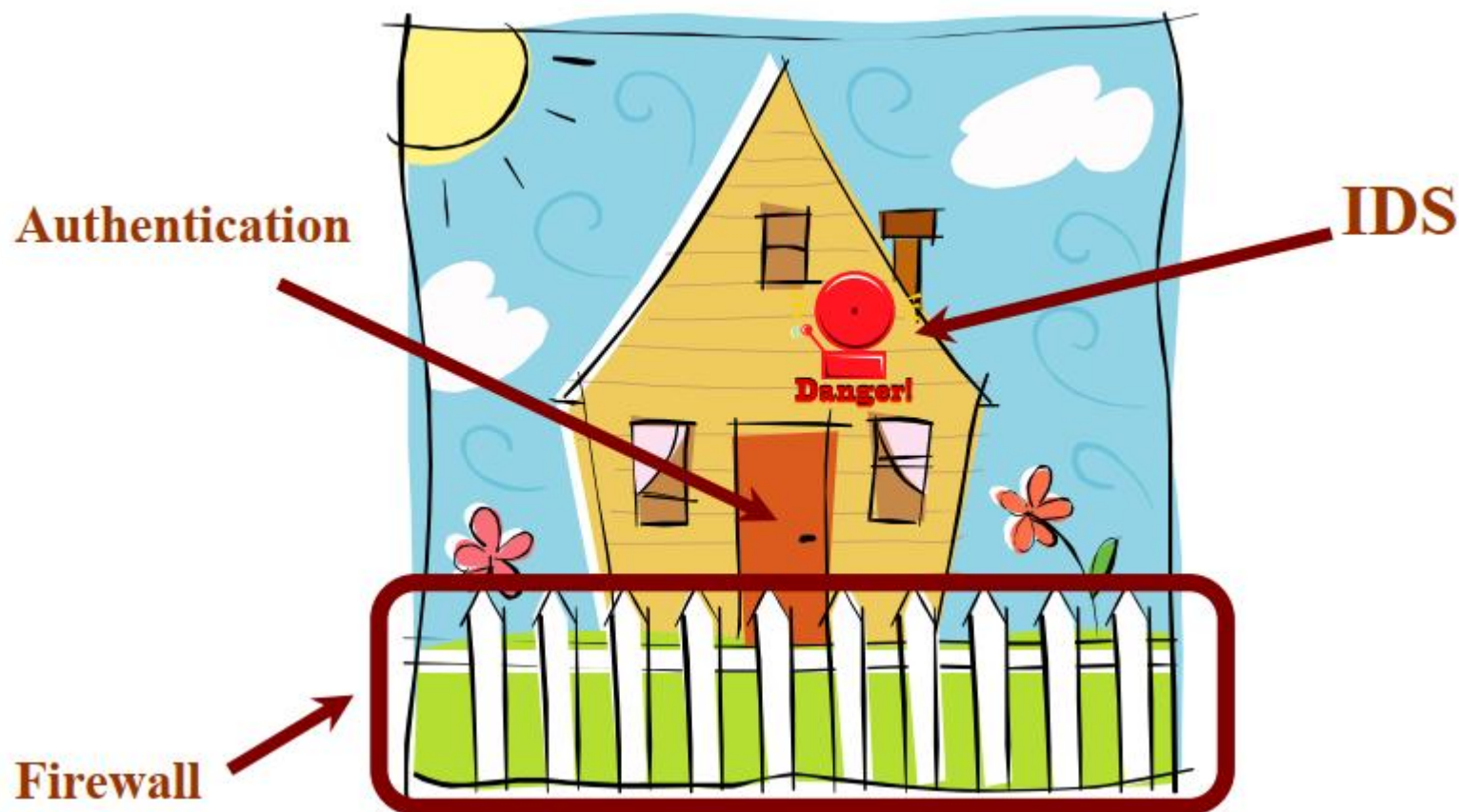
МРЕЖОВО АДМИНИСТРИРАНЕ

Термини и понятия

- **Intrusion Detection System (IDS)** – всяко средство, което автоматично регистрира, анализира и сигнализира всяка неототоризирана активност в дадена комуникационна мрежа или крайна система;
- **Intrusion Prevention System (IPS)** – система, която при сигнализиране на нарушение (intrusion) активира мерки за неговото отстраняване;
- ◆ **Пример:** Ако защитната стена е ключалката на вратата на една къща, то IDS е алармата срещу проникване с взлом. Защитната стена е мрежовия елемент осигуряващ защитата. В случай че защитата е преодоляна, IDS включва алармата и сигнализира (на COT), а IPS (фирмата за охрана - COT) отстранява нарушителя.

МРЕЖОВО АДМИНИСТРИРАНЕ

Термини и понятия



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Системи за откриване на нарушения (IDS)

➤ IDS се използват за:

- Защита от **известни заплахи** – извършва се на базата на търсене на познати модели в съдържанието на трафика и събитията;
- Защита от **неизвестни заплахи** – извършва се чрез изграждане на хипотези за класифициране на открити събития като заплаха, чрез изкуствен интелект, експертни системи или адаптивно филтриране на трафика;
- **Защита от блокиране на мрежа или система** – чрез анализ на трафика към системата се откриват атаки, които водят до претоварване на мрежата с трафик или определени ресурси на крайната система;

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Системи за откриване на нарушения (IDS)

- IDS използва два метода за анализ на пакети:
 - Сигнатурен анализ (**Signature-based IDS**) – търсят се предварително дефинирани поредици от символи (модели/образци) в постъпващите пакети;
 - ◆ Всеки постъпил пакет се проверява дали съвпада с някой от образците;
 - ◆ При съвпадение се маркира за по-нататъшна проверка;
 - ◆ Проблем: няма информация и съответно образци за нови атаки (за да има трябва някой да е бил атакуван и да е направен анализ на атаката);
 - ◆ Важно е времето за изготвяне на актуализации на знанията на IDS;
 - ◆ Добре е ако има възможност за изготвяне на собствени библиотеки с образци с цел изключване на правила, които не се отнасят до конкретната мрежа;

МРЕЖОВО АДМИНИСТРИРАНЕ

Системи за откриване на нарушения (IDS)

- IDS използва два метода за анализ на пакети:
 - Анализ на аномалиите (**Statistical-based IDS**) – използват се модели, чрез които мрежовия трафик се класифицира на нормален и необичаен;
 - ◆ Необходимо е да се обучат затова кое е нормално поведение и кое не;
 - ◆ Нивото на чувствителност може да доведе до твърде много алармени сигнали;
 - ◆ За да се открият аномалиите се предполага, че даден протокол има краен брой легални начини на функциониране и всеки друг начин е подозрителен;

МРЕЖОВО АДМИНИСТРИРАНЕ

Системи за откриване на нарушения (IDS)

➤ Какви данни се използват при анализа?

- Данни от защитните стени;
- Записи от *event-log* файловете на ОС или на IDS;
- Данни от пасивни устройства – снифери;
- Данни от пакетни филтри – TCP wrappers;
- Данни от проверка на целостта на файловете – MD5 суми;
- др.

МРЕЖОВО АДМИНИСТРИРАНЕ

Системи за откриване на нарушения (IDS)

- **Кои елементи на ИТ системата трябва да са обект да действието и?**
- Входни точки на мрежовия трафик;
- Критични сървъри;
- ◆ Сървъри за приложения;
- ◆ Уеб сървъри;
- ◆ DNS сървъри;
- ◆ Database сървъри
- Зоните в мрежата с изисквания за висока сигурност;
- др.

МРЕЖОВО АДМИНИСТРИРАНЕ

Типове IDS

➤ **Хост базирани (HIDS)** - система, която се намира на отделен хост в мрежата. Нейната задача е да открива само атаки насочени към този конкретен хост.

- **Предимства на HIDS:**

- ◆ като специализиран слой, се добавя защитен софтуер към уязвимите или чувствителни системи;
- ◆ следи дейностите за да открива подозрително поведение
 - основната цел е да се открият прониквания, да се регистрират подозрителни събития и да се изпращат сигнали
 - могат да откриват както външни, така и вътрешни интрузии;
- ◆ в голяма степен може да се има доверие в нея, за предоставяне на информация за всяка атака към дадения хост;

МРЕЖОВО АДМИНИСТРИРАНЕ

Типове IDS

- **Недостатъци на HIDS:**

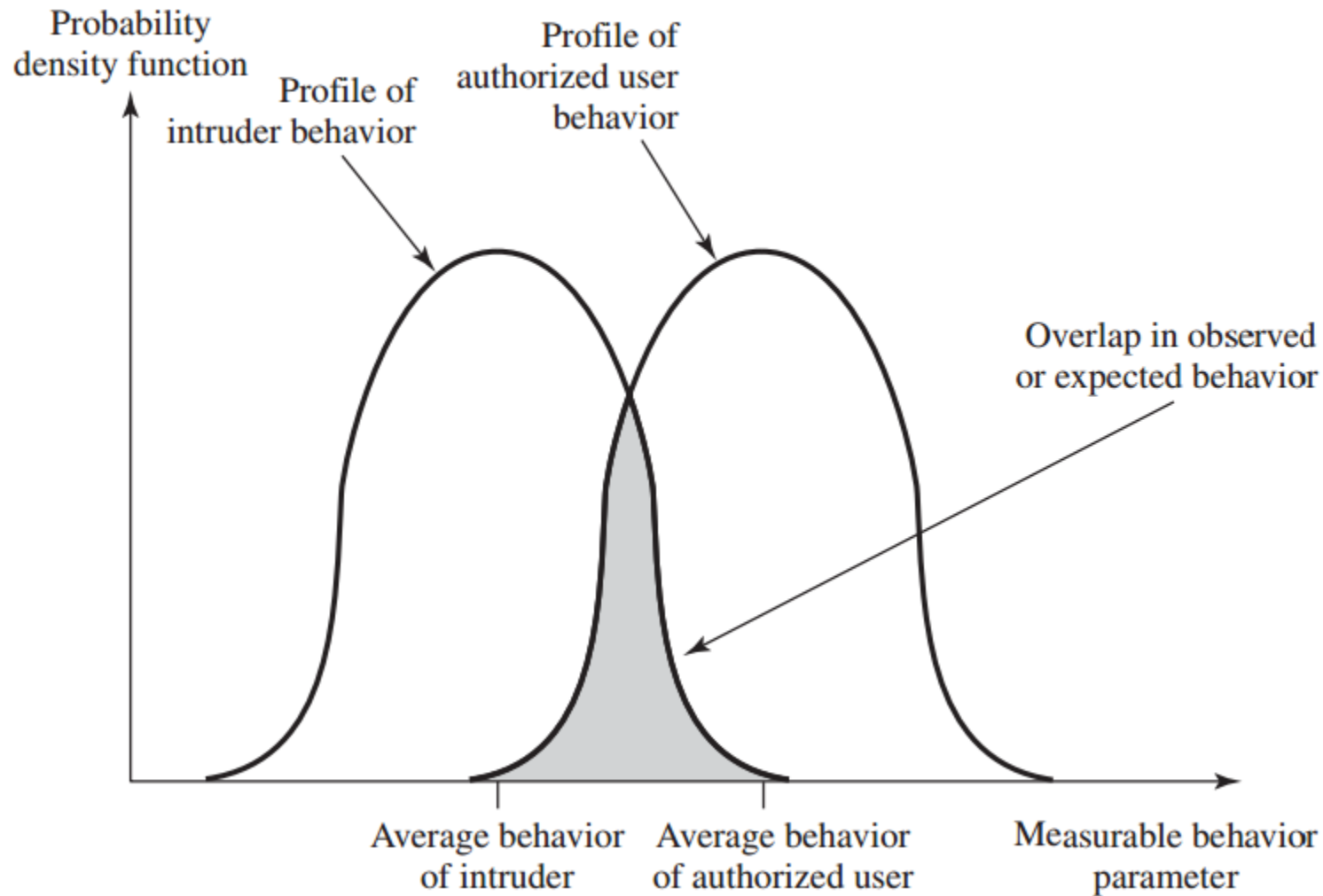
- ◆ Зависимост от ОС, което в хетерогенни мрежи означава, че ще има необходимост от различни IDS;
- ◆ При липса на централизирано управление ще има затруднение с администрирането и актуализирането;
- ◆ По-големи разходи;
- ◆ Използват само информацията, която хоста записва;
- ◆ Логовете на хоста могат да бъдат подправени;

- **Използвани методи при HIDS**

- ◆ **Откриване на аномалии** – използват се гранични стойности и профили за всеки потребител;
- ◆ **Откриване на сигнатури** - опит за дефиниране на набор от правила или модели на атаки, които могат да се използват, за да се реши, че дадено поведение е поведение на нарушител;

МРЕЖОВО АДМИНИСТРИРАНЕ

◆ Профили на поведение на нарушители и оторизирани потребители



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

◆ Характеристики, които могат се използват при HIDS:

Measure	Model	Type of Intrusion Detected
Login and Session Activity		
Login frequency by day and time	Mean and standard deviation	Intruders may be likely to log in during off-hours.
Frequency of login at different locations	Mean and standard deviation	Intruders may log in from a location that a particular user rarely or never uses.
Time since last login	Operational	Break-in on a "dead" account.
Elapsed time per session	Mean and standard deviation	Significant deviations might indicate masquerader.
Quantity of output to location	Mean and standard deviation	Excessive amounts of data transmitted to remote locations could signify leakage of sensitive data.
Session resource utilization	Mean and standard deviation	Unusual processor or I/O levels could signal an intruder.
Password failures at login	Operational	Attempted break-in by password guessing.
Failures to login from specified terminals	Operational	Attempted break-in.
Command or Program Execution Activity		
Execution frequency	Mean and standard deviation	May detect intruders, who are likely to use different commands, or a successful penetration by a legitimate user, who has gained access to privileged commands.
Program resource utilization	Mean and standard deviation	An abnormal value might suggest injection of a virus or Trojan horse, which performs side-effects that increase I/O or processor utilization.
Execution denials	Operational model	May detect penetration attempt by individual user who seeks higher privileges.
File Access Activity		
Read, write, create, delete frequency	Mean and standard deviation	Abnormalities for read and write access for individual users may signify masquerading or browsing.
Records read, written	Mean and standard deviation	Abnormality could signify an attempt to obtain sensitive data by inference and aggregation.
Failure count for read, write, create, delete	Operational	May detect users who persistently attempt to access unauthorized files.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Типове IDS

➤ **Мрежово базирани (NIDS)** – анализират трафика в цялата мрежа или мрежов сегмент (мрежови, транспортни и приложни протоколи) за да открият подозрителни действия;

- **Предимства на NIDS:**

- ◆ Дават възможност за целия поток от данни с сегмента, а не само в определен хост;
- ◆ Могат да бъдат открити опити за единични и разпределени атаки (DDoS), както и необичайна активност от определени хостове;
- ◆ Могат да се открият аномалии в заглавните части на пакетите;
- ◆ Могат да се открият необичайни събития в мрежата;

МРЕЖОВО АДМИНИСТРИРАНЕ

Типове IDS

- **Недостатъци на NIDS:**

- ◆ Анализирането на мрежовия трафик води до неговото забавяне;
- ◆ Проблеми ако трафикът е криптиран;
- ◆ Загубата на пакети може да затрудни процеса;
- ◆ Фрагментацията на пакети води до усложнения;
- ◆ Особенности на инсталирането;
- ◆ Проблеми с пропускателната способност над 300-400Mbps;
- ◆ Увеличаването на мощта на хардуера помага незначително;

МРЕЖОВО АДМИНИСТРИРАНЕ

Типове IDS

➤ **Хибридни системи** – комбинация от другите две;

**Основни
различия:**

Мрежови системи за детектиране на интрузия	Хост базирани системи за детектиране на интрузия
Контрол на цялата мрежова активност	Контрол на активност в рамките на хоста
Лесно инсталиране.	По-трудно инсталиране и настройване
По-добра детекция на атака от външна мрежа.	По-добра детекция на атака тип „от вътре”
По-лесна настройка.	По-трудна настройка.
Детекцията се базира на събития в цялата мрежа	Детекцията се базира на събития в една крайна система – хост.
Изследване на съдържанието на заглавните части на пакетите	Не се изследва съдържанието на заглавните части на пакетите.
Има възможност за реакция в реално време на системата.	Системата реагира само след като намери записано събитие в контролираните файлове.
Независимост от операционните системи в мрежата.	Специално разработени за конкретна операционна система.
Детектира атаките в мрежата, който се в полезния товар на пакетите.	Детектира локалните атаки, преди те да са навлезли в мрежата.
Детектира неуспешните атаки.	Верифицира успеха или неуспеха на дадена атака.

доц. д-р инж. Росен Радков

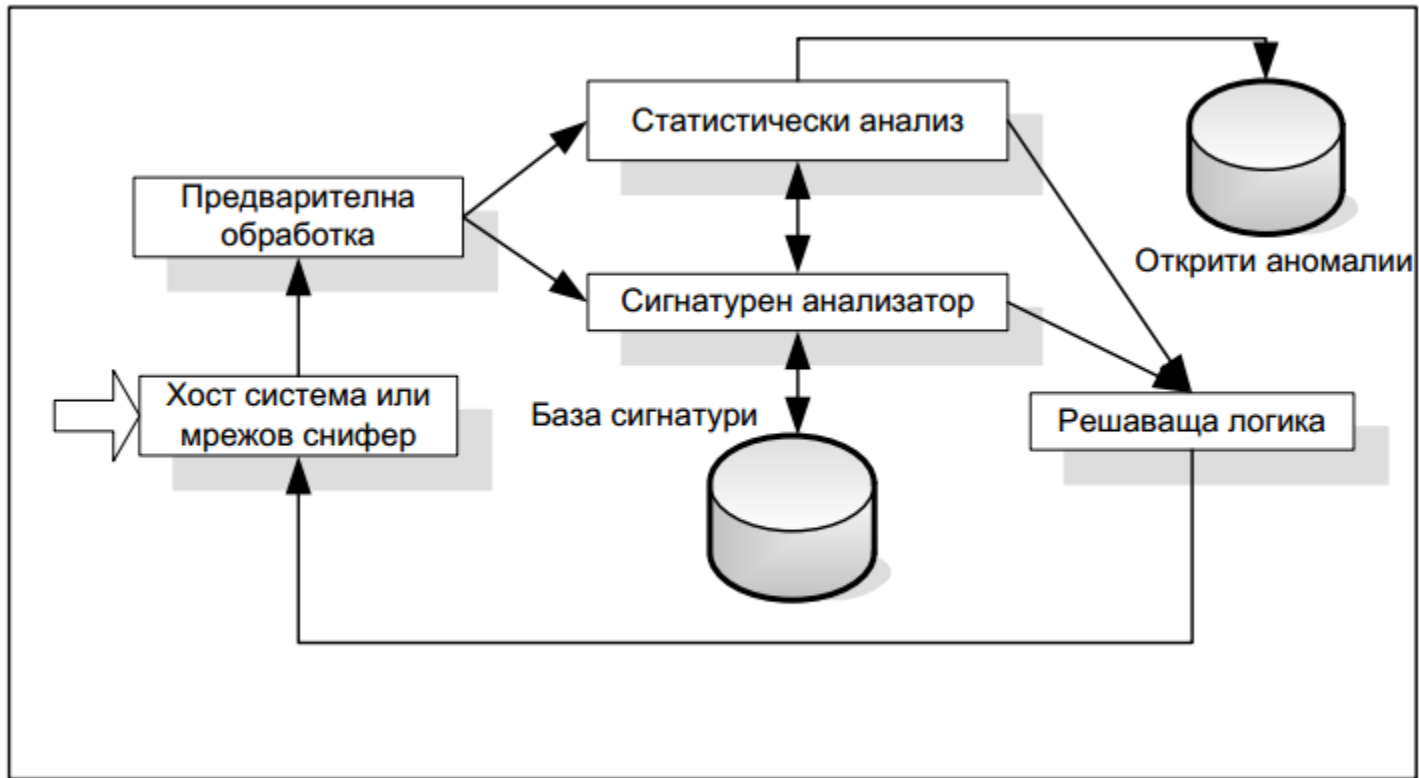
МРЕЖОВО АДМИНИСТРИРАНЕ

Изисквания към IDS

- Да работи непрекъснато
- Да бъде отказоустойчива система
- Да бъде устойчива на опити за компрометиране
- Минимално да натоварва системата
- Да бъде конфигурирана в съответствие с политиката за сигурност
- Лесно да се адаптира към промени в системата и потребителите
- Да бъде мащабируема
- Да позволява динамично реконфигуриране

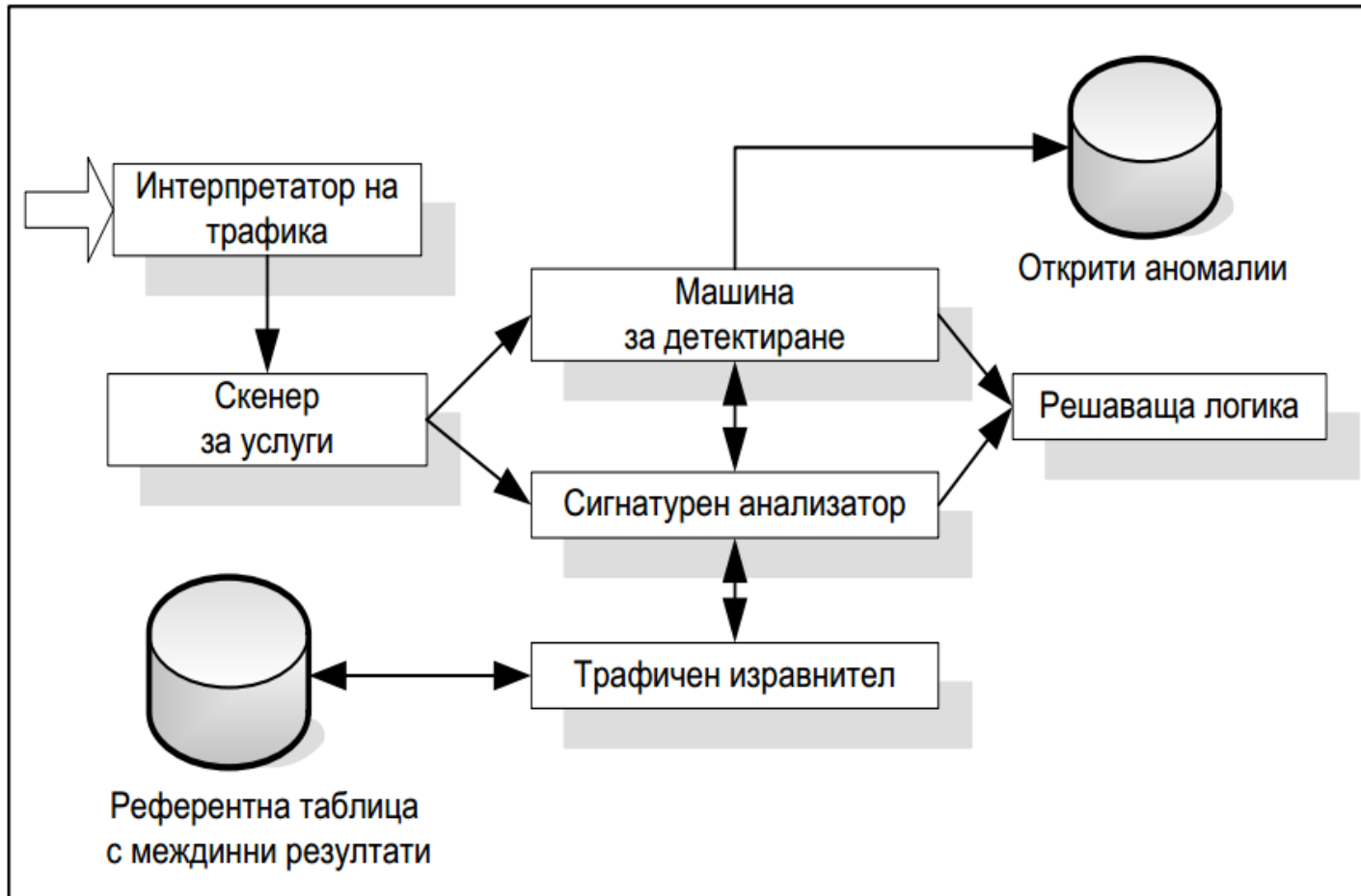
МРЕЖОВО АДМИНИСТРИРАНЕ

Принципна схема на IDS



МРЕЖОВО АДМИНИСТРИРАНЕ

Принципна схема на IPS



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Сравнение на IDS с IPS

IDS	IPS
Инсталира се в мрежов сегмент или на хост	Инсталира се в мрежов сегмент или на хост
Активно сканиране	Пасивно сканиране – по сигнал
Не може да обработва криптиран трафик	Обработва криптиран трафик
Централизиран мениджмънт	Централизиран мениджмънт
По-добро детектиране на хакерски атаки	Подходяща за блокиране на WWW
Предупреждаващ продукт	Блокиращ продукт

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектури на IDS

Възможни са три варианта:

- **Централизирана** (*single-tired*) - е реализация, при която IDS и IPS, колекционират и обработват данни сами за себе си, без да ги изпращат на други компоненти. Пример за такава архитектура е хост базираната. Тя ползва за източник на данни съответните системни файлове за регистриране на събития (sys-, event-log). Получените данни се сравняват с предварително подготвени шаблони (*patterns*), които представляват предварително дефинирани поредици от символи.

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

- **Разпределена** (*multi-tired*) - е реализация, която включва използването на специализирани компоненти, обменящи данни помежду си. Компонентите са разположени в различни точки на мрежата/мрежовия сегмент и събират информация за определени събития в него.
- **Сензори** – регистрират събития и аномалии и изпращат информацията за анализ;
- **Анализатори** (агенти) – получават данни от сензорите и ги анализират на базата на определени правила. Обикновено агентите изпълняват само един тип анализ, например един проверява FTP трафик, друг HTTP, трети SMTP и т.н.;

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

- **Мениджър** – може да предприеме действие като:
 - ◆ изпращане на алармено съобщение към конзола;
 - ◆ позвъняване на пейджър или телефон;
 - ◆ запис на информация за инцидента в база данни;
 - ◆ търсене на допълнителна информация, свързана с инцидента;
 - ◆ изпращане на инструкция до атакувания хост за прекратяване на определени процеси;
 - ◆ изпращане на команда до защитната стена или рутера на мрежата за промяна на правата за достъп за определени адреси;
 - ◆ изпращане на SMS;

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

- **Архитектура от тип точка-точка (*peer-to-peer*)** - дава възможност за обмен на информация между две системи за детектиране на интрузия, изпълняващи сходни функции. Много често тя се използва за обединение на дейността на няколко системи за IDS и IPS. При разпознаване на ново интрузионно събитие в дадена система, тя изпраща данните за него до друга системата (с която е свързана). Последната променя контролните си функции и базата данни (*access list*), с която разполага. По този начин тя може да разпознае тази нова атака в момента на възникването ѝ.

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

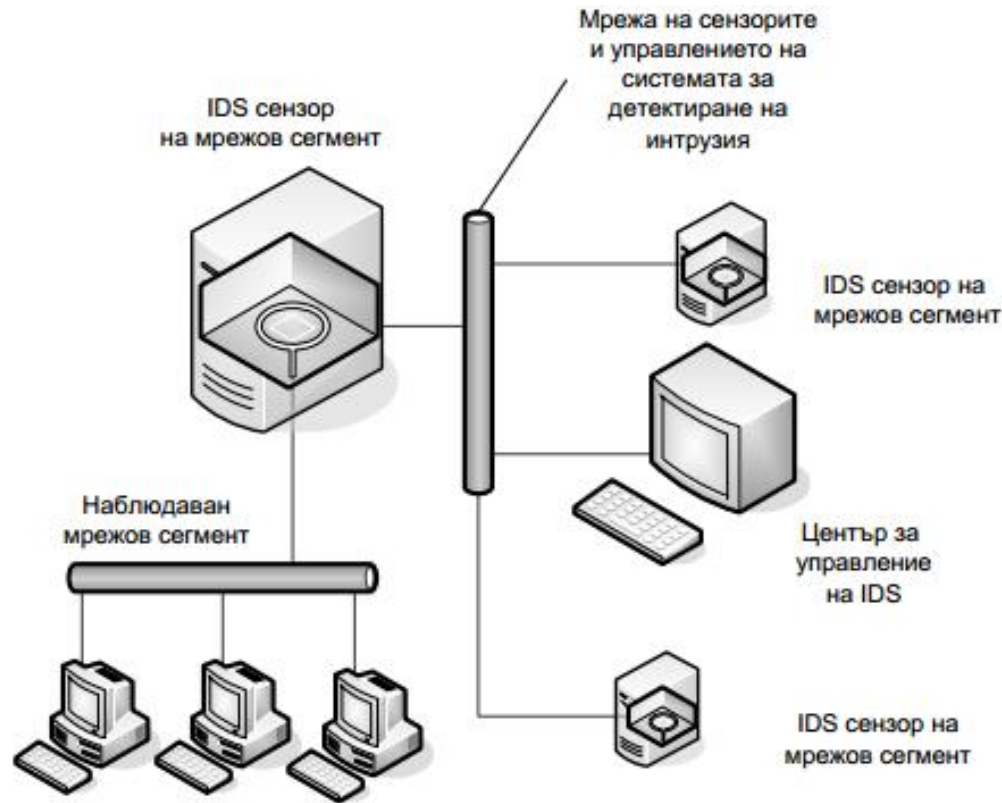
- **Сензори**

- ◆ Мрежови - по-често се използват. Представяват програми или специализирани мрежови устройства, които прихващат трафика в локалната мрежа или в мрежов сегмент. Не трябва да внасят закъснения в мрежата, породени от допълнителната обработка на пакетите;
- ◆ Хост-базирани - следят пакетите, постъпили в мрежовия интерфейс. За целта мрежовата карта се поставя в режим на работа – *promiscuous mode*. В този режим се прихващат всички постъпили пакети от порта на мрежовото устройство (switch, hub). Колекционирани данни се изпращат към анализаторите.

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

Местоположение на сензорите

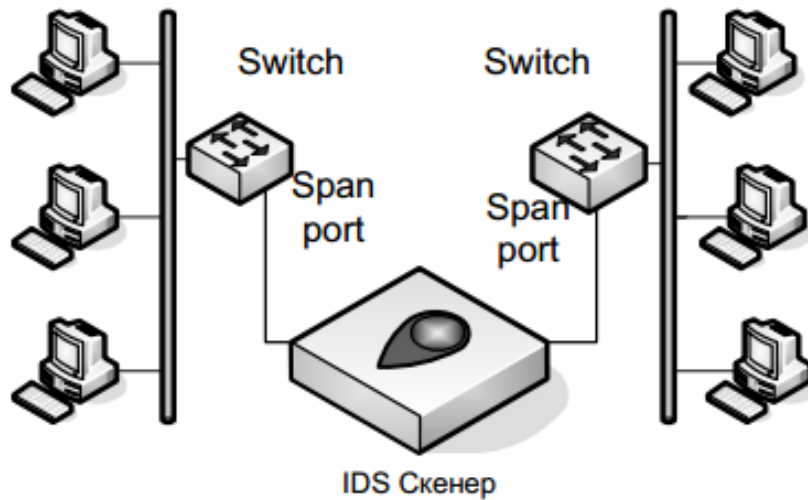


доц. д-р инж. Росен Радков

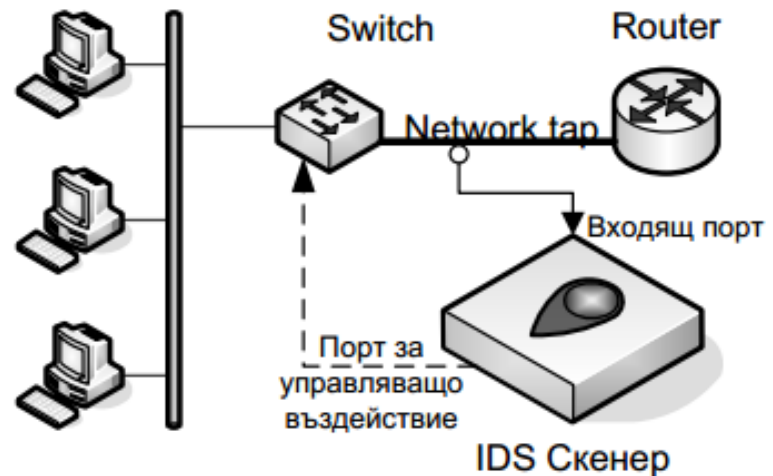
МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

Схема на свързване на мрежов сензор



Свързване към Mirror port

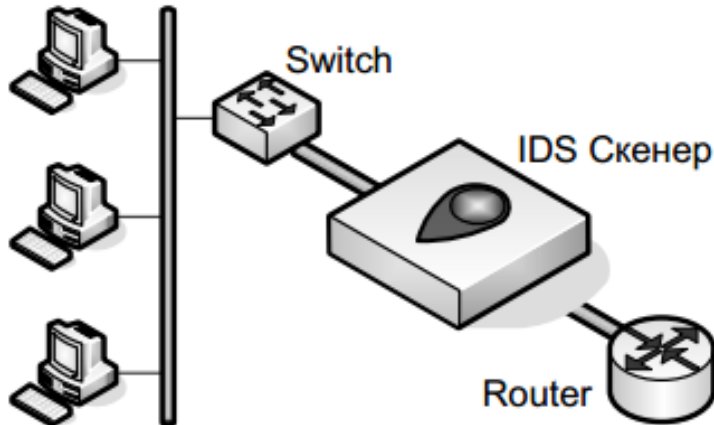


Свързване с Test Access Point (TAP)

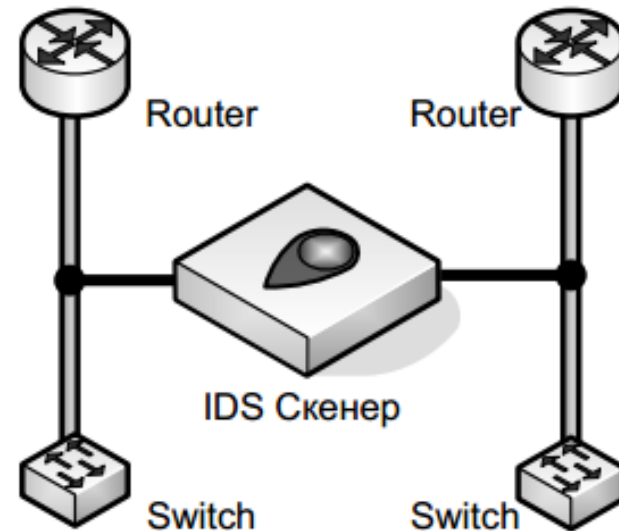
МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

Схема на свързване на мрежов сензор



Свързване в прозрачен режим

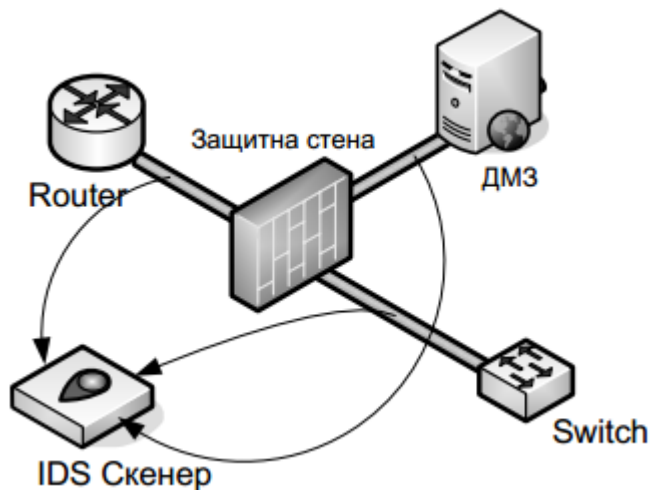


Свързване на многопортов сензор

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

Схема на свързване на мрежов сензор



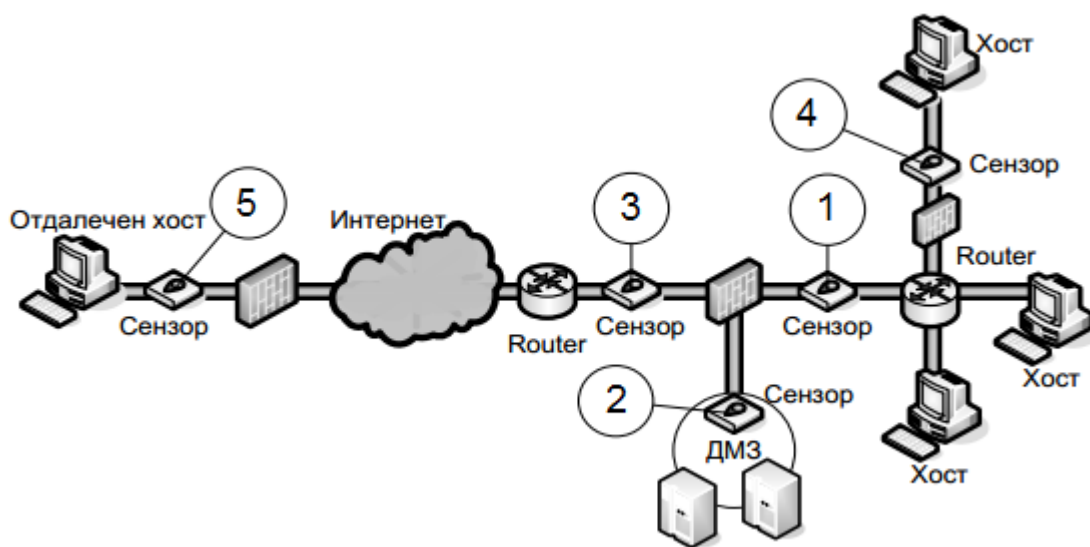
Свързването на сензор е направено така, че да се следи:

- входящия трафик от външната мрежа, идващ от рутера;
- трафика, филтриран от защитната стена, който постъпва във вътрешната мрежа;
- трафика, отклоняван към демилитализираната зона.

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

Схема на свързване на мрежов сензор



1. В зоната между вътрешна и външна мрежа
2. DMZ
3. Интернет трафик
4. Вътрешни сървъри
5. Отдалечени локации

МРЕЖОВО АДМИНИСТРИРАНЕ

Архитектура на IDS

- **Агенти**

- ◆ Те са група процеси стартирани независимо един от друг;
- ◆ Трябва да са независими един от друг;
- ◆ Добре е да се стартират на отделни хостове;
- ◆ Взаимодействието между тях помага да се отсеят фалшивите аларми;
- ◆ Изисква се да притежават следните свойства:
 - адаптивност;
 - ефективност;
 - гъвкавост;
 - независимост;
 - мащабируемост;
 - мобилност.

доц. д-р инж. Росен Радков

Архитектура на IDS

- **Мениджъри**

- ◆ Те са управляващата част на системата;
- ◆ Трябва да са съхраняват надеждно събраната информация;
- ◆ Анализират данните и извличат информация за настъпили събития. Анализът е свързан с корелация на събитията;
- ◆ Генерират алармени съобщения;
- ◆ Извършват мониторинг на сензорите и агентите;

МРЕЖОВО АДМИНИСТРИРАНЕ

Обмен на съобщенията при IDS

Intrusion Detection Message Exchange Requirements (RFC 4766):

Определя изискванията за Intrusion Detection Message Exchange Format (IDMEF). Документът също така определя изисквания за протокола за комуникация IDMEF.

The Intrusion Detection Message Exchange Format (RFC 4765):

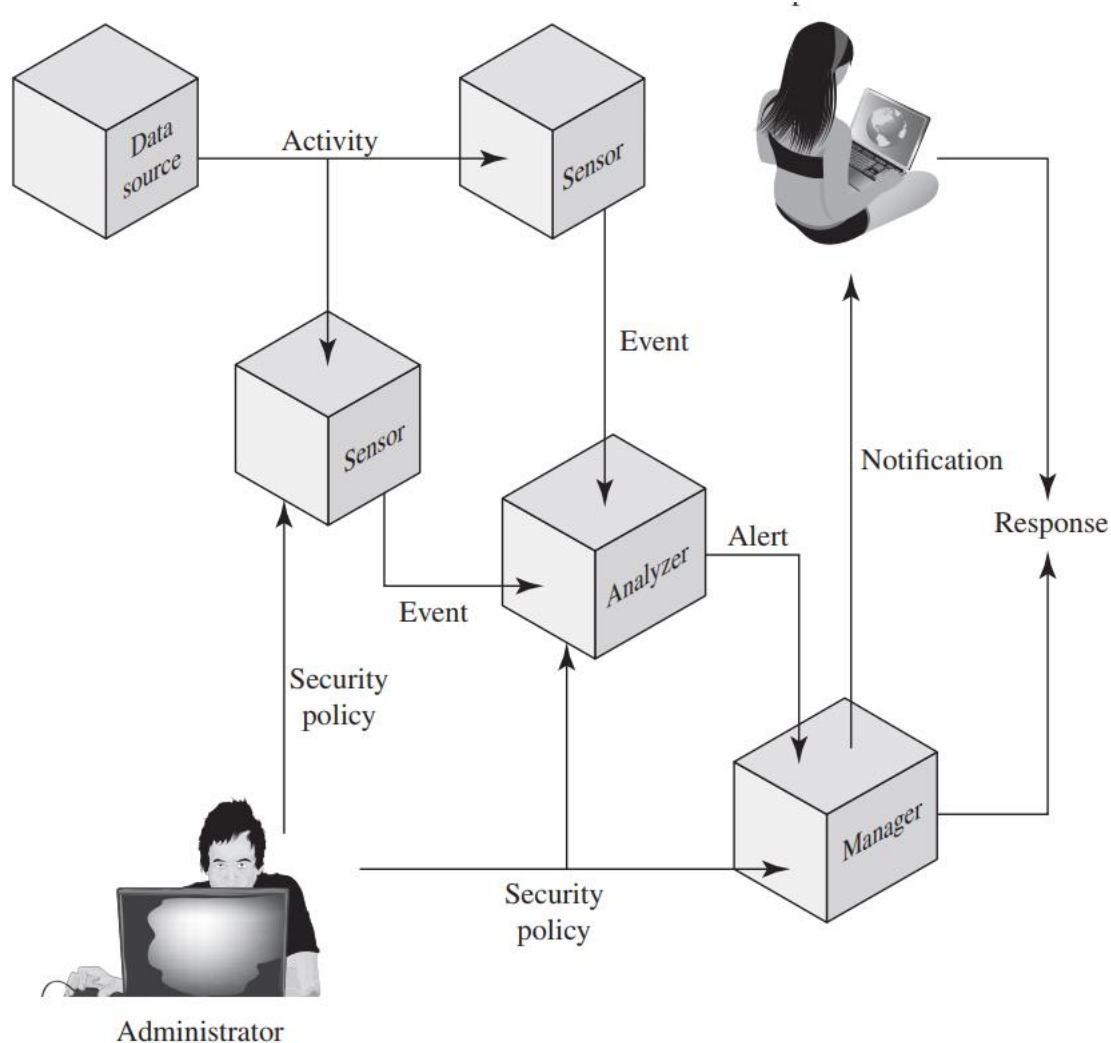
Описва модел на данни за представяне на информация, експортирана от системи за откриване на проникване, и обяснява обосновката за използването на този модел. Представено е прилагане на данновия модел в Extensible Markup Language (XML) формати са предоставени примери.

The Intrusion Detection Exchange Protocol (RFC 4767): Описва Intrusion Detection Exchange Protocol (IDXP), който е приложен протокол за обмен на данни между компонентите на IDS. IDXP поддържа взаимно удостоверяване, цялостност и поверителност и е connection-oriented протокол.

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

Обмен на съобщенията при IDS



доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

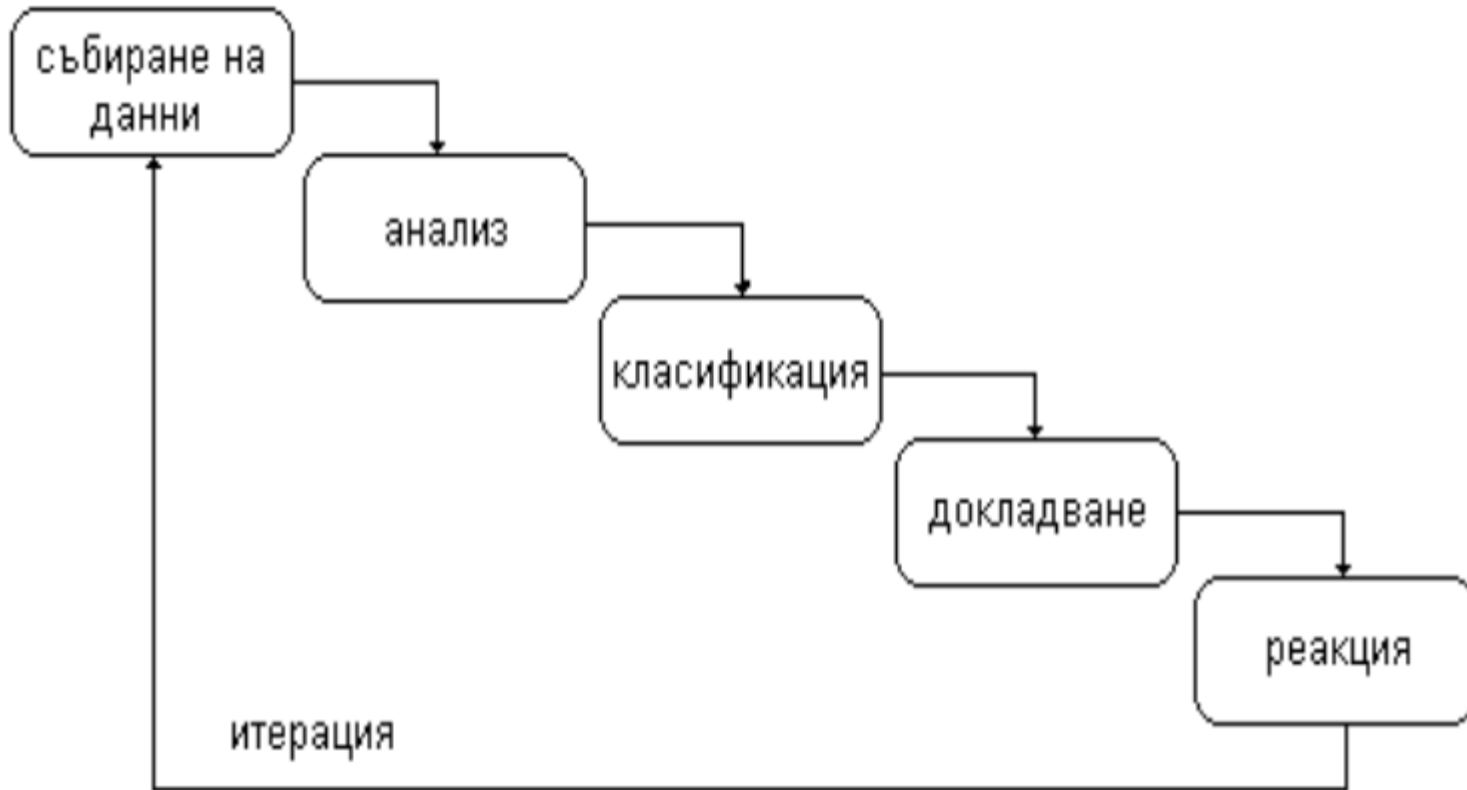
Анализ за откриване на нарушение

➤ Процесът протича в четири фази

- **Предварителна обработка** - има за задача да представи събраните данни в подходяща форма за анализ. Възможностите са две – или да се опишат в някаква канонична форма (мета език) или да се запишат в предварително структурирана релационна база данни.;
- **Анализ** - провежда се чрез: търсене на шаблони (сигнатурен анализ), детекция на трафична (или системна) аномалност и търсене на промени в определени обекти.;
- **Отговор**
- **Пренастройка**

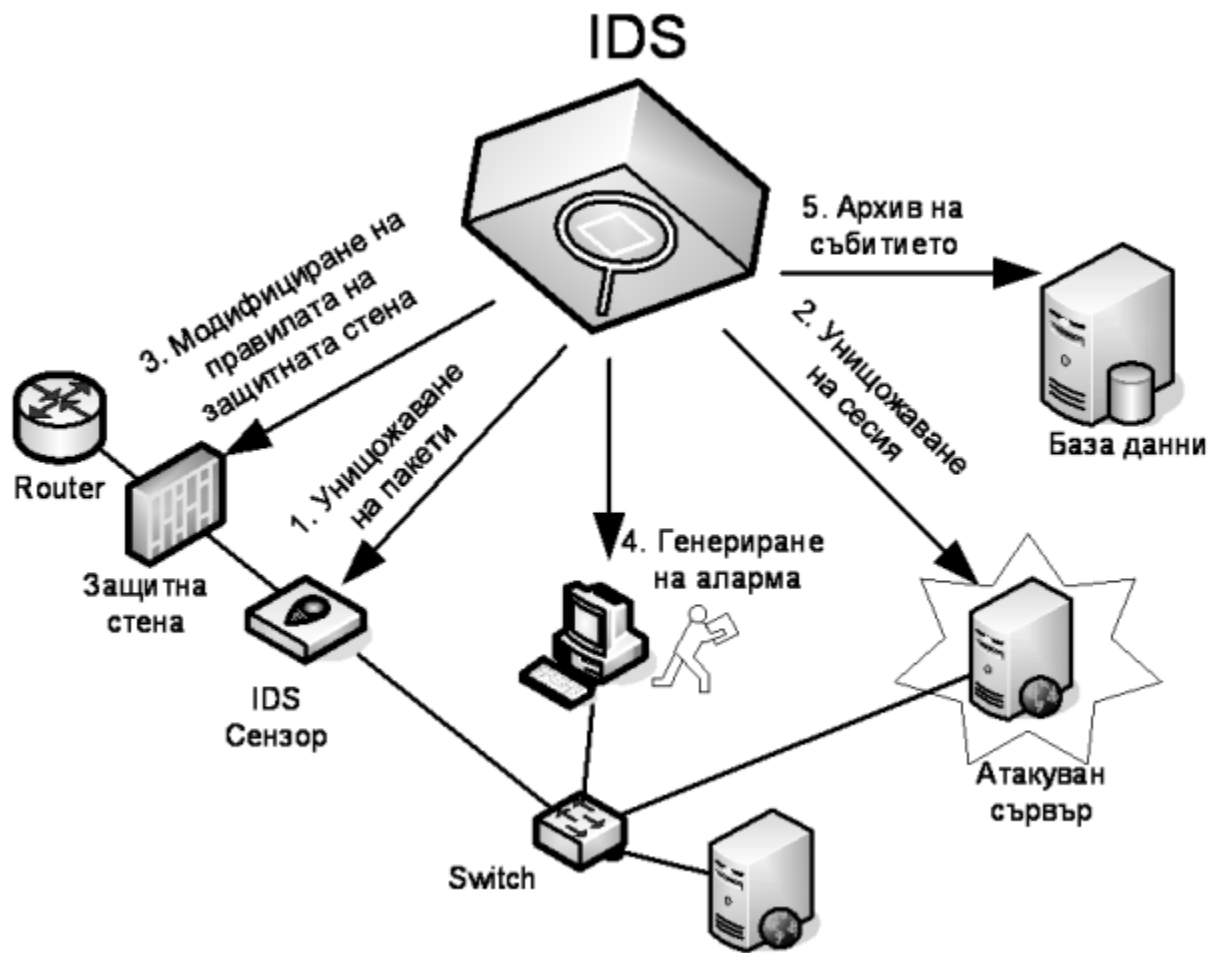
МРЕЖОВО АДМИНИСТРИРАНЕ

Модел на процеса на откриване на нарушение



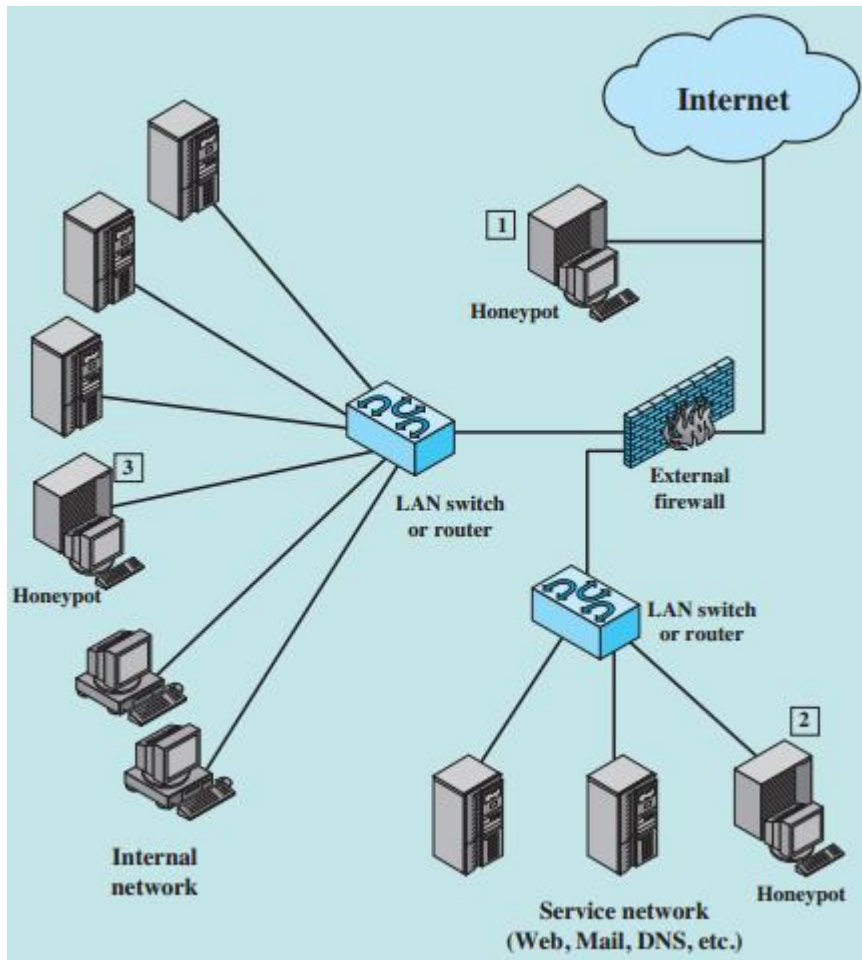
МРЕЖОВО АДМИНИСТРИРАНЕ

Действия при процеса на откриване на нарушение



МРЕЖОВО АДМИНИСТРИРАНЕ

Системи за примамка – Honeypot, Honeynet, Padded cells



Honeypot са предназначени за:

- примамване на потенциалния нападател далеч от критичните системи
- събиране на информация за дейността на атакуващия
- насърчаване на нападателя да остане в системата достатъчно дълго, за да може администраторите да отговорят
- съдържат измислена информация, и легитимните потребители на системата нямат достъп до тях
- съдържат ресурси, които нямат производствена стойност
- входящата комуникация обичайно е проба, сканиране на портове или атака
- наличието на изходяща комуникация предполага, че системата вероятно е била компрометирана
- след като хакерите са в мрежата, администраторите могат да наблюдават поведението им за да разберат как да изградят защитите

доц. д-р инж. Росен Радков

МРЕЖОВО АДМИНИСТРИРАНЕ

БЛАГОДАРЯ ЗА ВНИМАНИЕТО!

доц. д-р инж. Росен Радков